

Mapeo de preguntas a requisitos normativos

Nº pregunta	Tema principal	Posible relación normativa (ejemplos)
2.2	Política de cuantificación económica	ISO 27001 A.5, A.8; NIS2 art. 21; ENS principios de gestión del riesgo
2.3	Órganos de gobierno que revisan el riesgo	NIS2 art. 20 (responsabilidad de la dirección); Buenas prácticas de gobierno corporativo
2.4	Frecuencia de reporting al órgano de gobierno	NIS2 art. 20; Recomendaciones de supervisores financieros sobre ciber-riesgo
3.1	Uso general de FAIR	ISO 27005; EIOPA/ESMA guías sobre cuantificación de riesgos; marcos internos de gestión de riesgos
3.2	Finalidades del análisis FAIR	NIS2 (medidas de gestión de riesgos); supervisión sectorial (finanzas, energía, etc.)
3.3	Dominios cubiertos (IT, OT, datos personales)	GDPR; NIS2; ENS; regulación de operadores de servicios esenciales e infraestructuras críticas
4.1	Registro de incidentes	GDPR art. 33–34; NIS2 requisitos de notificación; ENS requisitos de registro de eventos
4.2	Fuentes para TEF	NIS2 (gestión de amenazas); Buenas prácticas de ciberinteligencia
5.1	Formas de pérdida cuantificadas	IFRS/NIIF (reconocimiento de pérdidas); guías de supervisores financieros sobre riesgo operacional
5.4	Fuentes para valorar económicamente las pérdidas	Normativa contable nacional y europea; requisitos de auditoría
6.1	Cálculo de ALE	Prácticas de gestión de riesgos basados en capital económico (finanzas, seguros)
6.2	Uso de percentiles de pérdida	Normativa de riesgos financieros (Basel, Solvencia II, etc. por analogía)
7.1	Evaluación de eficacia de controles	ISO 27001 A.5–A.8; ENS niveles de madurez; NIS2 (medidas técnicas y organizativas proporcionadas)

8.1	Criterios de materialidad	Normas contables y de información financiera; obligaciones de información al mercado
8.3	Inclusión de obligaciones normativas en pérdidas	GDPR (multas administrativas); NIS2 (sanciones); regulación sectorial
9.1	Automatización del proceso de cuantificación	No tiene referencia directa, pero se alinea con principios de mejora continua (ISO 27001, ENS)
10.1	Integración con continuidad de negocio	ISO 22301; ENS (continuidade del servicio); NIS2 (gestión de incidentes y continuidad)
11.1	Participación en iniciativas sectoriales/nacionales	Políticas nacionales de ciberseguridad; estrategias de cooperación público-privada
11.3	Contribución a indicadores de país	Estrategias nacionales de ciberseguridad; marcos de medición de riesgo país